

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **US - 33 CFR Part 101 Subpart F (up to date as of 4 - 17 - 2026)**

Focal Document URL: <https://www.ecfr.gov/current/title-33/chapter-I/subchapter-H/part-101/subpart-F>

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-usa-federal-law-33-cfr-part-101-subpart-f.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
101.600	Purpose	The purpose of this subpart is to set minimum cybersecurity requirements for U.S.-flagged vessels, facilities, and Outer Continental Shelf (OCS) facilities to safeguard and ensure the security and resilience of the Marine Transportation System (MTS).	Functional	No Relationship	N/A	N/A	N/A	0	
101.605	Applicability	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
101.605(a)	N/A	This subpart applies to the owners and operators of U.S.-flagged vessels, facilities, and OCS facilities required to have a security plan under 33 CFR parts 104, 105, and 106.	Functional	Intersects With	Compliance Scope	CPL-01.2	Mechanisms exist to document and validate the scope of security, compliance and resilience controls that are determined to meet statutory, regulatory and/or contractual compliance obligations.	5	
101.605(b)	N/A	This subpart does not apply to any foreign-flagged vessels subject to 33 CFR part 104.	Functional	Intersects With	Compliance Scope	CPL-01.2	Mechanisms exist to document and validate the scope of security, compliance and resilience controls that are determined to meet statutory, regulatory and/or contractual compliance obligations.	5	
101.610	Federalism	Consistent with § 101.112(b), with respect to a facility regulated under 33 CFR part 105 to which this subpart applies, the regulations in this subpart have preemptive effect over a State or local law or regulation insofar as the State or local law or regulation applicable to the facility conflicts with these regulations, either by actually conflicting or by frustrating an overriding Federal need for uniformity.	Functional	No Relationship	N/A	N/A	N/A	0	
101.615	Definitions	See FDE for specifics.	Functional	Subset Of	Standardized Terminology	SEA-02.1	Mechanisms exist to standardize technology and process terminology to reduce confusion amongst groups and departments.	10	
101.62	Owner or operator	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
101.620(a)	N/A	Each owner or operator of a U.S.-flagged vessel, facility, or OCS facility is responsible for compliance with the requirements of this subpart.	Functional	Subset Of	Statutory, Regulatory & Contractual Compliance	CPL-01	Mechanisms exist to facilitate the identification and implementation of relevant statutory, regulatory and contractual controls.	10	
101.620(b)	N/A	For each U.S.-flagged vessel, facility, or OCS facility, the owner or operator must—	Functional	No Relationship	N/A	N/A	N/A	0	
101.620(b)(1)	N/A	Ensure a Cybersecurity Plan is developed, approved, and maintained;	Functional	Subset Of	Security, Compliance & Resilience Program (SCRPP)	GOV-01	Mechanisms exist to facilitate the implementation of security, compliance and resilience governance controls.	10	
101.620(b)(2)	N/A	Define in Section 1 of the Cybersecurity Plan the cybersecurity organizational structure and identify each person exercising cybersecurity duties and responsibilities within that structure, with the support needed to fulfill those obligations;	Functional	Intersects With	Assigned Security, Compliance & Resilience Responsibilities	GOV-04	Mechanisms exist to assign one or more qualified individuals with the mission and resources to centrally-manage, coordinate, develop, implement and maintain an enterprise-wide Security, Compliance & Resilience Program (SCRPP).	8	
101.620(b)(2)	N/A	Define in Section 1 of the Cybersecurity Plan the cybersecurity organizational structure and identify each person exercising cybersecurity duties and responsibilities within that structure, with the support needed to fulfill those obligations;	Functional	Intersects With	Stakeholder Accountability Structure	GOV-04.1	Mechanisms exist to enforce an accountability structure so that appropriate teams and individuals are empowered, responsible and trained for mapping, measuring and managing Technology Assets, Applications, Services and/or Data (TAASD)-related risks.	8	
101.620(b)(2)	N/A	Define in Section 1 of the Cybersecurity Plan the cybersecurity organizational structure and identify each person exercising cybersecurity duties and responsibilities within that structure, with the support needed to fulfill those obligations;	Functional	Intersects With	Defined Roles & Responsibilities	HRS-03	Mechanisms exist to define cybersecurity roles & responsibilities for all personnel.	8	
101.620(b)(3)	N/A	Designate, in writing, by name and by title, a Cybersecurity Officer (CySO) who is accessible to the Coast Guard 24 hours a day, 7 days a week, and identify how the CySO can be contacted at any time;	Functional	Intersects With	Assigned Security, Compliance & Resilience Responsibilities	GOV-04	Mechanisms exist to assign one or more qualified individuals with the mission and resources to centrally-manage, coordinate, develop, implement and maintain an enterprise-wide Security, Compliance & Resilience Program (SCRPP).	5	
101.620(b)(3)	N/A	Designate, in writing, by name and by title, a Cybersecurity Officer (CySO) who is accessible to the Coast Guard 24 hours a day, 7 days a week, and identify how the CySO can be contacted at any time;	Functional	Intersects With	Regulatory & Law Enforcement Contacts	IRO-14	Mechanisms exist to maintain incident response contacts with applicable regulatory and law enforcement agencies.	5	
101.620(b)(4)	N/A	Ensure that cybersecurity exercises, audits, and inspections, as well as the Cybersecurity Assessment, are conducted as required by this part and in accordance with the Cybersecurity Plan (see § 101.625(d)(1), (3), (6) and (7));	Functional	Subset Of	Statutory, Regulatory & Contractual Compliance	CPL-01	Mechanisms exist to facilitate the identification and implementation of relevant statutory, regulatory and contractual controls.	10	
101.620(b)(5)	N/A	Ensure that the U.S.-flagged vessel, facility, or OCS facility operates in compliance with the approved Cybersecurity Plan;	Functional	Subset Of	Statutory, Regulatory & Contractual Compliance	CPL-01	Mechanisms exist to facilitate the identification and implementation of relevant statutory, regulatory and contractual controls.	10	
101.620(b)(6)	N/A	Ensure the development, approval, and execution of the Cyber Incident Response Plan;	Functional	Intersects With	Incident Response Plan (IRP)	IRO-04	Mechanisms exist to maintain and make available a current and viable Incident Response Plan (IRP) to all stakeholders.	5	
101.620(b)(7)	N/A	For entities that have not reported to the Coast Guard pursuant to, or are not subject to, 33 CFR 6.16-1, ensure all reportable cyber incidents are reported to the National Response Center (NRC).	Functional	Intersects With	Cyber Incident Reporting for Sensitive / Regulated Data	IRO-10.2	Mechanisms exist to report sensitive and/or regulated data incidents in a timely manner.	5	
101.625(a)	Cybersecurity Officer	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
101.625(a)	Other duties	The Cybersecurity Officer (CySO) may serve in other roles or positions and may perform other duties within the owner's or operator's organization (U.S.-flagged vessel, facility, or OCS facility), provided the person is able to perform the duties and responsibilities required of the CySO by this part.	Functional	Intersects With	Position Categorization	HRS-02	Mechanisms exist to manage personnel security risk by assigning a risk designation to all positions and establishing screening criteria for individuals filling those positions.	5	
101.625(a)	Other duties	The Cybersecurity Officer (CySO) may serve in other roles or positions and may perform other duties within the owner's or operator's organization (U.S.-flagged vessel, facility, or OCS facility), provided the person is able to perform the duties and responsibilities required of the CySO by this part.	Functional	Intersects With	Defined Roles & Responsibilities	HRS-03	Mechanisms exist to define cybersecurity roles & responsibilities for all personnel.	5	
101.625(b)	Serving as CySO for Multiple Vessels, Facilities, or OCS Facilities	The same person may serve as the CySO for more than one U.S.-flagged vessel, facility, or OCS facility. If a person serves as the CySO for more than one U.S.-flagged vessel, facility, or OCS facility, the name of each U.S.-flagged vessel, facility, or OCS facility for which that person is the CySO must be listed in the Cybersecurity Plan of each U.S.-flagged vessel, facility, or OCS facility for which that person is the CySO.	Functional	No Relationship	N/A	N/A	N/A	0	
101.625(c)	Assigning Duties Permitted	The CySO may assign security duties to other U.S.-flagged vessel, facility, or OCS facility personnel; however, the CySO retains ultimate responsibility for these duties.	Functional	Subset Of	Assigned Security, Compliance & Resilience Responsibilities	GOV-04	Mechanisms exist to assign one or more qualified individuals with the mission and resources to centrally-manage, coordinate, develop, implement and maintain an enterprise-wide Security, Compliance & Resilience Program (SCRPP).	10	
101.625(d)	Responsibilities	For each U.S.-flagged vessel, facility, or OCS facility for which they are designated, the CySO must—	Functional	Intersects With	Compliance Scope	CPL-01.2	Mechanisms exist to document and validate the scope of security, compliance and resilience controls that are determined to meet statutory, regulatory and/or contractual compliance obligations.	5	
101.625(d)(1)	N/A	Ensure that the Cybersecurity Assessment is conducted as required by this part;	Functional	Intersects With	Risk Assessment	RSK-04	Mechanisms exist to conduct recurring assessments of risk that includes the likelihood and magnitude of harm, from unauthorized access, use, disclosure, disruption, modification or destruction of the organization's Technology Assets, Applications, Services and/or Data (TAASD).	5	
101.625(d)(2)	N/A	Ensure the cybersecurity measures in the Cybersecurity Plan are developed, implemented, and operating as intended;	Functional	Subset Of	Operationalizing Security, Compliance & Resilience Capabilities	GOV-15	Mechanisms exist to compel data and/or process owners to operationalize security, compliance and resilience practices for Technology Assets, Applications, Services and/or Data (TAASD) under their control.	10	
101.625(d)(2)	N/A	Ensure the cybersecurity measures in the Cybersecurity Plan are developed, implemented, and operating as intended;	Functional	Intersects With	Select Controls	GOV-15.1	Mechanisms exist to compel data and/or process owners to select required security, compliance and resilience controls for Technology Assets, Applications, Services and/or Data (TAASD) under their control.	8	
101.625(d)(2)	N/A	Ensure the cybersecurity measures in the Cybersecurity Plan are developed, implemented, and operating as intended;	Functional	Intersects With	Implement Controls	GOV-15.2	Mechanisms exist to compel data and/or process owners to implement required security, compliance and resilience controls for Technology Assets, Applications, Services and/or Data (TAASD) under their control.	8	
101.625(d)(2)	N/A	Ensure the cybersecurity measures in the Cybersecurity Plan are developed, implemented, and operating as intended;	Functional	Intersects With	Assess Controls	GOV-15.3	Mechanisms exist to compel data and/or process owners to assess if required security, compliance and resilience controls for Technology Assets, Applications, Services and/or Data (TAASD) under their control are: (1) Implemented correctly; and (2) Operating as intended.	8	
101.625(d)(3)	N/A	Ensure that an annual audit of the Cybersecurity Plan and its implementation is conducted and, if necessary, ensure that the Cybersecurity Plan is updated;	Functional	Intersects With	Periodic Audits	CPL-02.2	Mechanisms exist to conduct periodic audits of security, compliance and resilience controls to evaluate conformity with the organization's documented policies, standards and procedures.	5	
101.625(d)(4)	N/A	Ensure the Cyber Incident Response Plan is executed and exercised;	Functional	Subset Of	Incident Handling	IRO-02	Mechanisms exist to cover: (1) Preparation; (2) Automated event detection or manual incident report intake; (3) Analysis; (4) Containment; (5) Eradication; and (6) Recovery.	10	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
101.625(d)(5)	N/A	Ensure the Cybersecurity Plan is exercised in accordance with § 101.635(c);	Functional	Intersects With	Publishing Security, Compliance & Resilience Documentation	GOV-02	Mechanisms exist to establish, maintain and disseminate policies, standards and procedures necessary for secure, compliant and resilient capabilities.	8	
101.625(d)(5)	N/A	Ensure the Cybersecurity Plan is exercised in accordance with § 101.635(c);	Functional	Intersects With	Periodic Review & Update of Security, Compliance & Resilience Program	GOV-03	Mechanisms exist to review the Security, Compliance & Resilience Program (SCRPP), including policies, standards and procedures, at planned intervals or if significant changes occur to ensure their continuing suitability, adequacy and effectiveness.	8	
101.625(d)(5)	N/A	Ensure the Cybersecurity Plan is exercised in accordance with § 101.635(c);	Functional	Subset Of	Operationalizing Security, Compliance & Resilience Capabilities	GOV-15	Mechanisms exist to compel data and/or process owners to operationalize security, compliance and resilience practices for Technology Assets, Applications, Services and/or Data (TAASD) under their control.	10	
101.625(d)(5)	N/A	Ensure the Cybersecurity Plan is exercised in accordance with § 101.635(c);	Functional	Subset Of	Applied Security, Compliance and Resilience Controls Documentation	IAQ-03	Mechanisms exist to generate authoritative documentation (e.g., System Security Plan (SSP)) that: (1) Identifies key architectural and implementation information on in-scope Technology Assets, Applications and/or Services (TAAS); (2) Reflects the current state of applied security, compliance and resilience controls on applicable People, Processes, Technologies, Data and/or Facilities (PPTDF) that are contained within the system boundary; and (3) Provides a historical record of applied security controls, including changes.	10	
101.625(d)(6)	N/A	Arrange for cybersecurity inspections, which may be conducted as their own inspections, or in conjunction with any scheduled Coast Guard inspection of a U.S.-flagged vessel, facility, or OCS facility;	Functional	Intersects With	Ability To Demonstrate Conformity	CPL-01.3	Mechanisms exist to ensure the organization is able to demonstrate security, compliance and/or resilience capability conformity with applicable cybersecurity and data protection laws, regulations and/or contractual obligations.	5	
101.625(d)(6)	N/A	Arrange for cybersecurity inspections, which may be conducted as their own inspections, or in conjunction with any scheduled Coast Guard inspection of a U.S.-flagged vessel, facility, or OCS facility;	Functional	Intersects With	Investigation Access Restrictions	CPL-05.2	Mechanisms exist to support official investigations by provisioning government investigators with "least privileges" and "least functionality" to ensure that government investigators only have access to the Technology Assets, Applications, Services and/or Data (TAASD) needed to perform the investigation.	5	
101.625(d)(7)	N/A	Ensure the prompt correction of problems identified by exercises, audits, or inspections;	Functional	Subset Of	Security, Compliance & Resilience Controls Oversight	CPL-02	Mechanisms exist to provide a security, compliance and resilience controls oversight function that reports to the organization's executive leadership.	10	
101.625(d)(7)	N/A	Ensure the prompt correction of problems identified by exercises, audits, or inspections;	Functional	Intersects With	Corrective Action	CPL-02.3	Mechanisms exist to take corrective action to remediate instances of non-conformity with applicable statutory, regulatory, and/or contractual compliance obligations.	8	
101.625(d)(8)	N/A	Enhance the cybersecurity awareness and vigilance of personnel;	Functional	Intersects With	User Awareness	HRS-03.1	Mechanisms exist to communicate with users about their roles and responsibilities to maintain a safe and secure working environment.	5	
101.625(d)(8)	N/A	Enhance the cybersecurity awareness and vigilance of personnel;	Functional	Intersects With	Format Indoctrination	HRS-04.2	Mechanisms exist to formally educate authorized users on proper data handling practices for all the relevant types of data to which they have access.	8	
101.625(d)(8)	N/A	Enhance the cybersecurity awareness and vigilance of personnel;	Functional	Subset Of	Security, Compliance & Resilience-Minded Workforce	SAT-01	Mechanisms exist to facilitate the implementation of security workforce development and awareness controls.	10	
101.625(d)(8)	N/A	Enhance the cybersecurity awareness and vigilance of personnel;	Functional	Intersects With	Maintaining Workforce Development Relevancy	SAT-01.1	Mechanisms exist to periodically review security workforce development and awareness training to account for changes to: (1) Organizational policies, standards and procedures; (2) Assigned roles and responsibilities; (3) Relevant threats and risks; and (4) Technological developments.	8	
101.625(d)(8)	N/A	Enhance the cybersecurity awareness and vigilance of personnel;	Functional	Intersects With	Cyber Threat Environment	SAT-03.6	Mechanisms exist to provide role-based security, compliance and resilience awareness training that is current and relevant to the cyber threats that users might encounter in day-to-day business operations.	8	
101.625(d)(8)	N/A	Enhance the cybersecurity awareness and vigilance of personnel;	Functional	Intersects With	Threat Intelligence Reporting	THR-03.1	Mechanisms exist to utilize external threat intelligence feeds to generate and disseminate organization-specific security alerts, advisories and/or directives.	5	
101.625(d)(9)	N/A	Ensure adequate cybersecurity training of personnel;	Functional	Subset Of	Security, Compliance & Resilience Awareness Training	SAT-02	Mechanisms exist to provide all employees and contractors appropriate security, compliance and resilience awareness education and training that is relevant for their job function.	10	
101.625(d)(9)	N/A	Ensure adequate cybersecurity training of personnel;	Functional	Intersects With	Role-Based Security, Compliance & Resilience Training	SAT-03	Mechanisms exist to provide role-based security, compliance and resilience-related training: (1) Before authorizing access to the system or performing assigned duties; (2) When required by system changes; and (3) Annually thereafter.	8	
101.625(d)(10)	N/A	Ensure all reportable cyber incidents are recorded and reported to the owner or operator;	Functional	Subset Of	Incident Stakeholder Reporting	IRO-10	Mechanisms exist to timely-report incidents to applicable: (1) Internal stakeholders; (2) Affected clients & third-parties; and (3) Regulatory authorities.	10	
101.625(d)(10)	N/A	Ensure all reportable cyber incidents are recorded and reported to the owner or operator;	Functional	Intersects With	Cyber Incident Reporting for Sensitive / Regulated Data	IRO-10.2	Mechanisms exist to report sensitive and/or regulated data incidents in a timely manner.	5	
101.625(d)(10)	N/A	Ensure all reportable cyber incidents are recorded and reported to the owner or operator;	Functional	Intersects With	Serious Incident Reporting	IRO-10.5	Mechanisms exist to report any serious incident involving the organization's Technology Assets, Applications, Services and/or Data (TAASD) to relevant authorities in the locality where the incident occurred, in accordance with mandatory reporting: (1) Requirements; and (2) Timelines.	5	
101.625(d)(11)	N/A	Ensure that records required by this part are maintained in accordance with § 101.640;	Functional	Subset Of	Media & Data Retention	DCH-18	Mechanisms exist to retain media and data in accordance with applicable statutory, regulatory and contractual obligations.	10	
101.625(d)(12)	N/A	Ensure any reports as required by this part have been prepared and submitted;	Functional	Subset Of	Security, Compliance & Resilience Status Reporting	GOV-17	Mechanisms exist to submit status reporting of the organization's security, compliance and/or resilience program to applicable statutory and/or regulatory authorities, as required.	10	
101.625(d)(13)	N/A	Ensure that the Cybersecurity Plan, as well as proposed amendments to cybersecurity measures included in the Plan, are submitted for approval to the cognizant COTP or the Officer in Charge, Marine Inspections (OCMI) for facilities or OCS facilities, or to the Marine Safety Center (MSC) for U.S.-flagged vessels, prior to amending the Cybersecurity Plan, in accordance with § 101.630;	Functional	Intersects With	Security, Compliance & Resilience Status Reporting	GOV-17	Mechanisms exist to submit status reporting of the organization's security, compliance and/or resilience program to applicable statutory and/or regulatory authorities, as required.	5	
101.625(d)(14)	N/A	Ensure relevant security and management personnel are briefed regarding changes in cybersecurity conditions on board the U.S.-flagged vessel, facility, or OCS facility;	Functional	Intersects With	Status Reporting To Governing Body	GOV-01.2	Mechanisms exist to provide governance oversight reporting and recommendations to those entrusted to make executive decisions about matters considered material to the organization's Security, Compliance & Resilience Program (SCRPP).	3	
101.625(d)(14)	N/A	Ensure relevant security and management personnel are briefed regarding changes in cybersecurity conditions on board the U.S.-flagged vessel, facility, or OCS facility;	Functional	Intersects With	Exception Management	GOV-02.1	Mechanisms exist to prohibit exceptions to standards, except when the exception has been formally assessed for risk impact, approved and recorded.	3	
101.625(d)(14)	N/A	Ensure relevant security and management personnel are briefed regarding changes in cybersecurity conditions on board the U.S.-flagged vessel, facility, or OCS facility;	Functional	Intersects With	Threat Intelligence Reporting	THR-03.1	Mechanisms exist to utilize external threat intelligence feeds to generate and disseminate organization-specific security alerts, advisories and/or directives.	3	
101.625(d)(15)	N/A	Ensure identification and mitigation of all KEVs in critical IT or OT systems, without delay.	Functional	Intersects With	Attack Surface Scope	VPM-01.1	Mechanisms exist to define and manage the scope for its attack surface management activities.	5	
101.625(d)(15)	N/A	Ensure identification and mitigation of all KEVs in critical IT or OT systems, without delay.	Functional	Intersects With	Vulnerability Remediation Process	VPM-02	Mechanisms exist to ensure that vulnerabilities are properly identified, tracked and remediated.	8	
101.625(d)(15)	N/A	Ensure identification and mitigation of all KEVs in critical IT or OT systems, without delay.	Functional	Intersects With	Vulnerability Ranking	VPM-03	Mechanisms exist to identify and assign a risk ranking to newly discovered security vulnerabilities using reputable outside sources for security vulnerability information.	5	
101.625(d)(15)	N/A	Ensure identification and mitigation of all KEVs in critical IT or OT systems, without delay.	Functional	Intersects With	Software & Firmware Patching	VPM-05	Mechanisms exist to conduct software patching for all deployed Technology Assets, Applications and/or Services (TAAS), including firmware.	8	
101.625(e)	Qualifications	The CySD must have general knowledge, through training, education, or equivalent job experience, in the following:	Functional	Subset Of	Competency Requirements for Security-Related Positions	HRS-03.2	Mechanisms exist to ensure that all security-related positions are staffed by qualified individuals who have the necessary skill set.	10	
101.625(e)(1)	N/A	General vessel, facility, or OCS facility operations and conditions;	Functional	Subset Of	Competency Requirements for Security-Related Positions	HRS-03.2	Mechanisms exist to ensure that all security-related positions are staffed by qualified individuals who have the necessary skill set.	10	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
101.625(e)(2)	N/A	General cybersecurity guidance and best practices;	Functional	Subset Of	Competency Requirements for Security-Related Positions	HRS-03.2	Mechanisms exist to ensure that all security-related positions are staffed by qualified individuals who have the necessary skill set.	10	
101.625(e)(3)	N/A	The vessel, facility, or OCS facility's Cyber Incident Response Plan;	Functional	Subset Of	Competency Requirements for Security-Related Positions	HRS-03.2	Mechanisms exist to ensure that all security-related positions are staffed by qualified individuals who have the necessary skill set.	10	
101.625(e)(4)	N/A	The vessel, facility, or OCS facility's Cybersecurity Plan;	Functional	Subset Of	Competency Requirements for Security-Related Positions	HRS-03.2	Mechanisms exist to ensure that all security-related positions are staffed by qualified individuals who have the necessary skill set.	10	
101.625(e)(5)	N/A	Cybersecurity equipment and systems;	Functional	Subset Of	Competency Requirements for Security-Related Positions	HRS-03.2	Mechanisms exist to ensure that all security-related positions are staffed by qualified individuals who have the necessary skill set.	10	
101.625(e)(6)	N/A	Methods of conducting cybersecurity audits, inspections, control, and monitoring techniques;	Functional	Subset Of	Competency Requirements for Security-Related Positions	HRS-03.2	Mechanisms exist to ensure that all security-related positions are staffed by qualified individuals who have the necessary skill set.	10	
101.625(e)(7)	N/A	Relevant laws and regulations pertaining to cybersecurity;	Functional	Subset Of	Competency Requirements for Security-Related Positions	HRS-03.2	Mechanisms exist to ensure that all security-related positions are staffed by qualified individuals who have the necessary skill set.	10	
101.625(e)(8)	N/A	Instruction techniques for cybersecurity training and education;	Functional	Subset Of	Competency Requirements for Security-Related Positions	HRS-03.2	Mechanisms exist to ensure that all security-related positions are staffed by qualified individuals who have the necessary skill set.	10	
101.625(e)(9)	N/A	Handling of Sensitive Security Information and security related communications;	Functional	Subset Of	Competency Requirements for Security-Related Positions	HRS-03.2	Mechanisms exist to ensure that all security-related positions are staffed by qualified individuals who have the necessary skill set.	10	
101.625(e)(10)	N/A	Current cybersecurity threat patterns and KEVs;	Functional	Subset Of	Competency Requirements for Security-Related Positions	HRS-03.2	Mechanisms exist to ensure that all security-related positions are staffed by qualified individuals who have the necessary skill set.	10	
101.625(e)(11)	N/A	Recognizing characteristics and behavioral patterns of persons who are likely to threaten security; and	Functional	Subset Of	Competency Requirements for Security-Related Positions	HRS-03.2	Mechanisms exist to ensure that all security-related positions are staffed by qualified individuals who have the necessary skill set.	10	
101.625(e)(12)	N/A	Conducting and assessing cybersecurity drills and exercises.	Functional	Subset Of	Competency Requirements for Security-Related Positions	HRS-03.2	Mechanisms exist to ensure that all security-related positions are staffed by qualified individuals who have the necessary skill set.	10	
101.630(a)	Cybersecurity Plan	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
101.630(a)	General	The CySO must develop, implement, and verify a Cybersecurity Plan for U.S.-flagged vessels, facilities, or OCS facilities. The Cybersecurity Plan must reflect all cybersecurity measures required in this subpart, as appropriate, to mitigate risks identified during the Cybersecurity Assessment. The Plan must describe in detail how the requirements of subpart F will be met. The Cybersecurity Plan may be included in a VSP, FSP, or an OCS FSP; as an annex to the VSP, FSP, or OCS FSP; as part of an approved Alternative Security Program; or may be provided in a separate submission from the VSP, FSP, or OCS FSP.	Functional	Subset Of	Applied Security, Compliance and Resilience Controls Documentation	IAO-03	Mechanisms exist to generate authoritative documentation (e.g., System Security Plan (SSP)) that: (1) Identifies key architectural and implementation information on in-scope Technology Assets, Applications and/or Services (TAAS); (2) Reflects the current state of applied security, compliance and resilience controls on applicable People, Processes, Technologies, Data and/or Facilities (PPTDF) that are contained within the system boundary; and (3) Provides a historical record of applied security controls, including changes.	10	
101.630(b)	Protecting sensitive security information	The Cybersecurity Plan is sensitive security information and must be protected in accordance with 49 CFR part 1520.	Functional	Subset Of	Data Protection	DCH-01	Mechanisms exist to facilitate the implementation of data protection controls.	10	
101.630(b)	Protecting sensitive security information	The Cybersecurity Plan is sensitive security information and must be protected in accordance with 49 CFR part 1520.	Functional	Intersects With	Defining Access Authorizations for Sensitive / Regulated Data	DCH-01.4	Mechanisms exist to explicitly define authorizations for specific individuals and/or roles for logical and /or physical access to sensitive and/or regulated data.	8	
101.630(c)	Format	The owner or operator must ensure that the Cybersecurity Plan consists of the individual sections listed in this paragraph.	Functional	Subset Of	Applied Security, Compliance and Resilience Controls Documentation	IAO-03	Mechanisms exist to generate authoritative documentation (e.g., System Security Plan (SSP)) that: (1) Identifies key architectural and implementation information on in-scope Technology Assets, Applications and/or Services (TAAS); (2) Reflects the current state of applied security, compliance and resilience controls on applicable People, Processes, Technologies, Data and/or Facilities (PPTDF) that are contained within the system boundary; and (3) Provides a historical record of applied security controls, including changes.	10	
101.630(c)(1)	N/A	Cybersecurity organization and identity of the CySO;	Functional	Subset Of	Applied Security, Compliance and Resilience Controls Documentation	IAO-03	Mechanisms exist to generate authoritative documentation (e.g., System Security Plan (SSP)) that: (1) Identifies key architectural and implementation information on in-scope Technology Assets, Applications and/or Services (TAAS); (2) Reflects the current state of applied security, compliance and resilience controls on applicable People, Processes, Technologies, Data and/or Facilities (PPTDF) that are contained within the system boundary; and (3) Provides a historical record of applied security controls, including changes.	10	
101.630(c)(2)	N/A	Personnel training;	Functional	Subset Of	Applied Security, Compliance and Resilience Controls Documentation	IAO-03	Mechanisms exist to generate authoritative documentation (e.g., System Security Plan (SSP)) that: (1) Identifies key architectural and implementation information on in-scope Technology Assets, Applications and/or Services (TAAS); (2) Reflects the current state of applied security, compliance and resilience controls on applicable People, Processes, Technologies, Data and/or Facilities (PPTDF) that are contained within the system boundary; and (3) Provides a historical record of applied security controls, including changes.	10	
101.630(c)(3)	N/A	Drills and exercises;	Functional	Subset Of	Applied Security, Compliance and Resilience Controls Documentation	IAO-03	Mechanisms exist to generate authoritative documentation (e.g., System Security Plan (SSP)) that: (1) Identifies key architectural and implementation information on in-scope Technology Assets, Applications and/or Services (TAAS); (2) Reflects the current state of applied security, compliance and resilience controls on applicable People, Processes, Technologies, Data and/or Facilities (PPTDF) that are contained within the system boundary; and (3) Provides a historical record of applied security controls, including changes.	10	
101.630(c)(4)	N/A	Records and documentation;	Functional	Subset Of	Applied Security, Compliance and Resilience Controls Documentation	IAO-03	Mechanisms exist to generate authoritative documentation (e.g., System Security Plan (SSP)) that: (1) Identifies key architectural and implementation information on in-scope Technology Assets, Applications and/or Services (TAAS); (2) Reflects the current state of applied security, compliance and resilience controls on applicable People, Processes, Technologies, Data and/or Facilities (PPTDF) that are contained within the system boundary; and (3) Provides a historical record of applied security controls, including changes.	10	

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **US - 33 CFR Part 101 Subpart F (up to date as of 4 - 17 - 2026)**

Focal Document URL: <https://www.ecfr.gov/current/title-33/chapter-I/subchapter-H/part-101/subpart-F>

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-usa-federal-law-33-cfr-part-101-subpart-f.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
101.630(c)(5)	N/A	Communications;	Functional	Subset Of	Applied Security, Compliance and Resilience Controls Documentation	IAO-03	Mechanisms exist to generate authoritative documentation (e.g., System Security Plan (SSP)) that: (1) Identifies key architectural and implementation information on in-scope Technology Assets, Applications and/or Services (TAAS); (2) Reflects the current state of applied security, compliance and resilience controls on applicable People, Processes, Technologies, Data and/or Facilities (PPTDF) that are contained within the system boundary; and (3) Provides a historical record of applied security controls, including changes.	10	
101.630(c)(6)	N/A	Cybersecurity systems and equipment, with associated maintenance;	Functional	Subset Of	Applied Security, Compliance and Resilience Controls Documentation	IAO-03	Mechanisms exist to generate authoritative documentation (e.g., System Security Plan (SSP)) that: (1) Identifies key architectural and implementation information on in-scope Technology Assets, Applications and/or Services (TAAS); (2) Reflects the current state of applied security, compliance and resilience controls on applicable People, Processes, Technologies, Data and/or Facilities (PPTDF) that are contained within the system boundary; and (3) Provides a historical record of applied security controls, including changes.	10	
101.630(c)(7)	N/A	Cybersecurity measures for access control, including the computer, IT, and OT access areas;	Functional	Subset Of	Applied Security, Compliance and Resilience Controls Documentation	IAO-03	Mechanisms exist to generate authoritative documentation (e.g., System Security Plan (SSP)) that: (1) Identifies key architectural and implementation information on in-scope Technology Assets, Applications and/or Services (TAAS); (2) Reflects the current state of applied security, compliance and resilience controls on applicable People, Processes, Technologies, Data and/or Facilities (PPTDF) that are contained within the system boundary; and (3) Provides a historical record of applied security controls, including changes.	10	
101.630(c)(8)	N/A	Physical security controls for IT and OT systems;	Functional	Subset Of	Applied Security, Compliance and Resilience Controls Documentation	IAO-03	Mechanisms exist to generate authoritative documentation (e.g., System Security Plan (SSP)) that: (1) Identifies key architectural and implementation information on in-scope Technology Assets, Applications and/or Services (TAAS); (2) Reflects the current state of applied security, compliance and resilience controls on applicable People, Processes, Technologies, Data and/or Facilities (PPTDF) that are contained within the system boundary; and (3) Provides a historical record of applied security controls, including changes.	10	
101.630(c)(9)	N/A	Cybersecurity measures for monitoring;	Functional	Subset Of	Applied Security, Compliance and Resilience Controls Documentation	IAO-03	Mechanisms exist to generate authoritative documentation (e.g., System Security Plan (SSP)) that: (1) Identifies key architectural and implementation information on in-scope Technology Assets, Applications and/or Services (TAAS); (2) Reflects the current state of applied security, compliance and resilience controls on applicable People, Processes, Technologies, Data and/or Facilities (PPTDF) that are contained within the system boundary; and (3) Provides a historical record of applied security controls, including changes.	10	
101.630(c)(10)	N/A	Audits and amendments to the Cybersecurity Plan;	Functional	Subset Of	Applied Security, Compliance and Resilience Controls Documentation	IAO-03	Mechanisms exist to generate authoritative documentation (e.g., System Security Plan (SSP)) that: (1) Identifies key architectural and implementation information on in-scope Technology Assets, Applications and/or Services (TAAS); (2) Reflects the current state of applied security, compliance and resilience controls on applicable People, Processes, Technologies, Data and/or Facilities (PPTDF) that are contained within the system boundary; and (3) Provides a historical record of applied security controls, including changes.	10	
101.630(c)(11)	N/A	Reports of all cybersecurity audits and inspections, to include documentation of resolution or mitigation of all identified vulnerabilities;	Functional	Subset Of	Applied Security, Compliance and Resilience Controls Documentation	IAO-03	Mechanisms exist to generate authoritative documentation (e.g., System Security Plan (SSP)) that: (1) Identifies key architectural and implementation information on in-scope Technology Assets, Applications and/or Services (TAAS); (2) Reflects the current state of applied security, compliance and resilience controls on applicable People, Processes, Technologies, Data and/or Facilities (PPTDF) that are contained within the system boundary; and (3) Provides a historical record of applied security controls, including changes.	10	
101.630(c)(12)	N/A	Documentation of all identified, unresolved vulnerabilities, to include those that are intentionally unresolved due to owner or operator risk acceptance;	Functional	Subset Of	Applied Security, Compliance and Resilience Controls Documentation	IAO-03	Mechanisms exist to generate authoritative documentation (e.g., System Security Plan (SSP)) that: (1) Identifies key architectural and implementation information on in-scope Technology Assets, Applications and/or Services (TAAS); (2) Reflects the current state of applied security, compliance and resilience controls on applicable People, Processes, Technologies, Data and/or Facilities (PPTDF) that are contained within the system boundary; and (3) Provides a historical record of applied security controls, including changes.	10	
101.630(c)(13)	N/A	Cyber incident reporting procedures in accordance with part 101 of this subchapter;	Functional	Subset Of	Applied Security, Compliance and Resilience Controls Documentation	IAO-03	Mechanisms exist to generate authoritative documentation (e.g., System Security Plan (SSP)) that: (1) Identifies key architectural and implementation information on in-scope Technology Assets, Applications and/or Services (TAAS); (2) Reflects the current state of applied security, compliance and resilience controls on applicable People, Processes, Technologies, Data and/or Facilities (PPTDF) that are contained within the system boundary; and (3) Provides a historical record of applied security controls, including changes.	10	
101.630(c)(14)	N/A	Cybersecurity Assessment.	Functional	Subset Of	Applied Security, Compliance and Resilience Controls Documentation	IAO-03	Mechanisms exist to generate authoritative documentation (e.g., System Security Plan (SSP)) that: (1) Identifies key architectural and implementation information on in-scope Technology Assets, Applications and/or Services (TAAS); (2) Reflects the current state of applied security, compliance and resilience controls on applicable People, Processes, Technologies, Data and/or Facilities (PPTDF) that are contained within the system boundary; and (3) Provides a historical record of applied security controls, including changes.	10	
101.630(d)	Submission and approval	Each owner or operator must submit one copy of their Cybersecurity Plan for review and approval to the cognizant COTP or the OCMi for a facility or OCS facility, or to the MSC for a U.S.-flagged vessel.	Functional	Intersects With	Security, Compliance & Resilience Status Reporting	GOV-17	Mechanisms exist to submit status reporting of the organization's security, compliance and/or resilience program to applicable statutory and/or regulatory authorities, as required.	5	
101.630(d)(1)	N/A	The COTP, OCMi, or MSC will evaluate each submission for compliance with this part, and either—	Functional	No Relationship	N/A	N/A	N/A	0	
101.630(d)(1)(i)	N/A	Approve the Cybersecurity Plan and return a letter to the owner or operator indicating approval and any conditional approval;	Functional	No Relationship	N/A	N/A	N/A	0	
101.630(d)(1)(ii)	N/A	Require additional information or revisions to the Cybersecurity Plan and return a copy to the owner or operator with a brief description of the required revisions or additional information; or	Functional	No Relationship	N/A	N/A	N/A	0	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
101.630(d)(1)(iii)	N/A	Disapprove the Cybersecurity Plan and return a copy to the owner or operator with a brief statement of the reasons for disapproval.	Functional	No Relationship	N/A	N/A	N/A	0	
101.630(d)(1)(iv)	N/A	If the cognizant COTP, OCM, or MSC requires additional time to review the Plan, they may return a written acknowledgement to the owner or operator stating that the Coast Guard will review the Cybersecurity Plan submitted for approval, and that the U.S.-flagged vessel, facility, or OCS facility may continue to operate as long as it remains in compliance with the submitted Cybersecurity Plan.	Functional	No Relationship	N/A	N/A	N/A	0	
101.630(d)(2)	N/A	Owners or operators submitting one Cybersecurity Plan to cover two or more U.S.-flagged vessels, facilities, or OCS facilities of similar operations must ensure the Plan addresses the specific cybersecurity risks for each U.S.-flagged vessel, facility, or OCS facility.	Functional	Intersects With	Compliance Scope	CPL-01.2	Mechanisms exist to document and validate the scope of security, compliance and resilience controls that are determined to meet statutory, regulatory and/or contractual compliance obligations.	5	
101.630(d)(3)	N/A	A Plan that is approved by the COTP, OCM, or MSC is valid for 5 years from the date of its approval.	Functional	No Relationship	N/A	N/A	N/A	0	
101.630(e)	Amendments to the Cybersecurity Plan	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
101.630(e)(1)	N/A	Amendments to a Coast Guard-approved Cybersecurity Plan must be initiated by either—	Functional	No Relationship	N/A	N/A	N/A	0	
101.630(e)(1)(i)	N/A	The owner or operator or the CySO; or	Functional	No Relationship	N/A	N/A	N/A	0	
101.630(e)(1)(ii)	N/A	When the COTP, OCM, or MSC finds that the Cybersecurity Plan no longer meets the requirements in this part, the Plan will be returned to the owner or operator with a letter explaining why the Plan no longer meets the requirements and requires amendment.	Functional	No Relationship	N/A	N/A	N/A	0	
101.630(e)(2)	N/A	Proposed amendments to the Cybersecurity Plan must be sent to the Coast Guard at least 30 days before the proposed amendment's effective date.	Functional	Intersects With	Security, Compliance & Resilience Status Reporting	GOV-17	Mechanisms exist to submit status reporting of the organization's security, compliance and/or resilience program to applicable statutory and/or regulatory authorities, as required.	5	
101.630(e)(2)(i)	N/A	Nothing in this section should be construed as limiting the owner or operator of the U.S.-flagged vessel, facility, or OCS facility from the timely implementation of such additional security measures not enumerated in the approved VSP, FSP, or OCS FSP as necessary to address exigent security situations.	Functional	No Relationship	N/A	N/A	N/A	0	
101.630(e)(2)(ii)	N/A	In such cases, the owner or operator must notify the cognizant COTP for a facility or OCS facility, or the MSC for U.S.-flagged vessels, by the most rapid means practicable as to the nature of the additional measures, the circumstances that prompted these additional measures, and the period of time these additional measures are expected to be in place.	Functional	Intersects With	Security, Compliance & Resilience Status Reporting	GOV-17	Mechanisms exist to submit status reporting of the organization's security, compliance and/or resilience program to applicable statutory and/or regulatory authorities, as required.	5	
101.630(e)(3)	N/A	If the owner or operator has changed, the CySO must amend the Cybersecurity Plan as soon as reasonably practicable in light of the individual circumstances, but, in any case, not longer than 96 hours, to include the name and contact information of the new owner or operator and submit the affected portion of the Plan for review and approval in accordance with this part.	Functional	Intersects With	Security, Compliance & Resilience Status Reporting	GOV-17	Mechanisms exist to submit status reporting of the organization's security, compliance and/or resilience program to applicable statutory and/or regulatory authorities, as required.	5	
101.630(e)(4)	N/A	If the CySO has changed, the Coast Guard must be notified as soon as reasonably practicable in light of the individual circumstances, but, in any case, not longer than 96 hours, and the affected portion of the Cybersecurity Plan must be amended and submitted to the Coast Guard for review and approval in accordance with this part as soon as reasonably practicable in light of the individual circumstances, but, in any case, not longer than 96 hours.	Functional	Intersects With	Security, Compliance & Resilience Status Reporting	GOV-17	Mechanisms exist to submit status reporting of the organization's security, compliance and/or resilience program to applicable statutory and/or regulatory authorities, as required.	5	
101.630(f)	Audits	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
101.630(f)(1)	N/A	The CySO must ensure that an audit of the Cybersecurity Plan and its implementation is performed annually, beginning no later than 1 year from the initial date of approval. The CySO must attach a report to the Plan certifying that the Plan meets the applicable requirements of this subpart.	Functional	Subset Of	Control Conformity Monitoring	CPL-03	Mechanisms exist to validate that Technology Assets, Applications, Services and/or Data (TAASD) conform to the organization's security, compliance and/or resilience policies, standards and other applicable requirements.	10	
101.630(f)(2)	N/A	In addition to the annual audit, the CySO must ensure that an audit of the Cybersecurity Plan occurs if there is a change in the owner or operator of the U.S.-flagged vessel, facility, or OCS facility, or if there have been modifications to the cybersecurity measures, including, but not limited to, physical access, incident response procedures, security measures, or operations.	Functional	Subset Of	Control Conformity Monitoring	CPL-03	Mechanisms exist to validate that Technology Assets, Applications, Services and/or Data (TAASD) conform to the organization's security, compliance and/or resilience policies, standards and other applicable requirements.	10	
101.630(f)(3)	N/A	Additional audits of the Cybersecurity Plan as a result of modifications to the U.S.-flagged vessel, facility, or OCS facility, or because of changes to the cybersecurity measures in accordance with paragraph (f)(2) of this section, may be limited to those sections of the Plan affected by the modifications.	Functional	Intersects With	Security, Compliance & Resilience Status Reporting	GOV-17	Mechanisms exist to submit status reporting of the organization's security, compliance and/or resilience program to applicable statutory and/or regulatory authorities, as required.	5	
101.630(f)(4)	N/A	Personnel conducting internal audits of the cybersecurity measures specified in the Plan or evaluating its implementation must—	Functional	Intersects With	Assessment Team Subject Matter Expertise	CPL-01.6	Mechanisms exist to ensure individuals performing audits and/or assessments have reasonable: (1) Professional qualifications to perform the audit and/or assessment; and (2) Subject matter expertise to perform review, interview and test activities for in-scope People, Processes, Technologies, Data and/or Facilities (PPTDF).	5	
101.630(f)(4)(i)	N/A	Have knowledge of methods of conducting audits and inspections, as well as access control and monitoring techniques;	Functional	Intersects With	Assessment Team Subject Matter Expertise	CPL-01.6	Mechanisms exist to ensure individuals performing audits and/or assessments have reasonable: (1) Professional qualifications to perform the audit and/or assessment; and (2) Subject matter expertise to perform review, interview and test activities for in-scope People, Processes, Technologies, Data and/or Facilities (PPTDF).	5	
101.630(f)(4)(ii)	N/A	Not have regularly assigned cybersecurity duties for the U.S.-flagged vessel, facility, or OCS facility being audited; and	Functional	Intersects With	Independent Assessors	CPL-03.1	Mechanisms exist to utilize independent assessors to evaluate security, compliance and resilience at planned intervals or when the Technology Asset, Application and/or Service (TAAS) undergoes significant changes.	5	
101.630(f)(4)(iii)	N/A	Be independent of any cybersecurity measures being audited.	Functional	Intersects With	Independent Assessors	CPL-03.1	Mechanisms exist to utilize independent assessors to evaluate security, compliance and resilience at planned intervals or when the Technology Asset, Application and/or Service (TAAS) undergoes significant changes.	5	
101.630(f)(5)	N/A	If the results of an audit require amending the Cybersecurity Plan, the CySO must submit, in accordance with this part, the amendments to the Coast Guard for review and approval no later than 30 days after completion of the audit.	Functional	Intersects With	Security, Compliance & Resilience Status Reporting	GOV-17	Mechanisms exist to submit status reporting of the organization's security, compliance and/or resilience program to applicable statutory and/or regulatory authorities, as required.	5	
101.635	Drills and exercises	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
101.635(a)	General	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
101.635(a)(1)	N/A	Drills and exercises must be used to test the proficiency of the U.S.-flagged vessel, facility, and OCS facility personnel in assigned cybersecurity duties and the effective implementation of the VSP, FSP, OCS FSP, and Cybersecurity Plan. The drills and exercises must enable the CySO to identify any related cybersecurity deficiencies that need to be addressed.	Functional	Intersects With	Incident Response Testing	IRO-06	Mechanisms exist to formally test incident response capabilities through realistic exercises to determine the operational effectiveness of those capabilities.	8	
101.635(a)(1)	N/A	Drills and exercises must be used to test the proficiency of the U.S.-flagged vessel, facility, and OCS facility personnel in assigned cybersecurity duties and the effective implementation of the VSP, FSP, OCS FSP, and Cybersecurity Plan. The drills and exercises must enable the CySO to identify any related cybersecurity deficiencies that need to be addressed.	Functional	Intersects With	Coordination with Related Plans	IRO-06.1	Mechanisms exist to coordinate incident response testing with organizational elements responsible for related plans.	8	
101.635(b)(2)	N/A	The drill or exercise requirements specified in this section may be satisfied with the implementation of cybersecurity measures required by the VSP, FSP, OCS FSP, and Cybersecurity Plan as the result of a cyber incident, as long as the U.S.-flagged vessel, facility, or OCS facility achieves and documents attainment of drill and exercise goals for the cognizant COTP.	Functional	No Relationship	N/A	N/A	N/A	0	
101.635(b)	Drills	N/A	Functional	No Relationship	N/A	N/A	N/A	0	

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **US - 33 CFR Part 101 Subpart F (up to date as of 4 - 17 - 2026)**

Focal Document URL: <https://www.ecfr.gov/current/title-33/chapter-I/subchapter-H/part-101/subpart-F>

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-usa-federal-law-33-cfr-part-101-subpart-f.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
101.635(b)(1)	N/A	The CySO must ensure that cybersecurity drills are conducted at least twice each calendar year. Cybersecurity drills may be held in conjunction with other security or non-security drills, as required by 33 CFR 104.230, 105.220, or 106.225, where appropriate.	Functional	Intersects With	Incident Response Testing	IRO-06	Mechanisms exist to formally test incident response capabilities through realistic exercises to determine the operational effectiveness of those capabilities.	5	
101.635(b)(2)	N/A	Drills must test individual elements of the Cybersecurity Plan, including responses to cybersecurity threats and incidents. Cybersecurity drills must take into account the types of operations of the U.S.-flagged vessel, facility, or OCS facility; changes to the U.S.-flagged vessel, facility, or OCS facility personnel; the type of vessel a facility is serving; and other relevant circumstances.	Functional	Intersects With	Incident Response Testing	IRO-06	Mechanisms exist to formally test incident response capabilities through realistic exercises to determine the operational effectiveness of those capabilities.	5	
101.635(b)(3)	N/A	If a vessel is moored at a facility on a date a facility has planned to conduct any drills, the facility cannot require the vessel or vessel personnel to be a part of or participate in the facility's scheduled drill.	Functional	Intersects With	Incident Response Testing	IRO-06	Mechanisms exist to formally test incident response capabilities through realistic exercises to determine the operational effectiveness of those capabilities.	5	
101.635(c)	Exercises	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
101.635(c)(1)	N/A	Exercises must be conducted at least once each calendar year, with no more than 18 months between exercises.	Functional	Intersects With	Incident Response Testing	IRO-06	Mechanisms exist to formally test incident response capabilities through realistic exercises to determine the operational effectiveness of those capabilities.	5	
101.635(c)(2)	N/A	Exercises may be—	Functional	Intersects With	Incident Response Testing	IRO-06	Mechanisms exist to formally test incident response capabilities through realistic exercises to determine the operational effectiveness of those capabilities.	5	
101.635(c)(2)(i)	N/A	Full-scale or live;	Functional	Intersects With	Incident Response Testing	IRO-06	Mechanisms exist to formally test incident response capabilities through realistic exercises to determine the operational effectiveness of those capabilities.	5	
101.635(c)(2)(ii)	N/A	Tabletop simulation;	Functional	Intersects With	Incident Response Testing	IRO-06	Mechanisms exist to formally test incident response capabilities through realistic exercises to determine the operational effectiveness of those capabilities.	5	
101.635(c)(2)(iii)	N/A	Combined with other appropriate exercises as required by 33 CFR 104.230, 105.220, or 106.225; or	Functional	Intersects With	Incident Response Testing	IRO-06	Mechanisms exist to formally test incident response capabilities through realistic exercises to determine the operational effectiveness of those capabilities.	5	
101.635(c)(2)(iv)	N/A	A combination of the elements in paragraphs (c)(2)(i) through (iii) of this section.	Functional	Intersects With	Incident Response Testing	IRO-06	Mechanisms exist to formally test incident response capabilities through realistic exercises to determine the operational effectiveness of those capabilities.	5	
101.635(c)(3)	N/A	Exercises may be vessel-, facility-, or OCS facility-specific, or part of a cooperative exercise program to exercise applicable vessel, facility, and OCS facility Cybersecurity Plans or comprehensive port exercises.	Functional	Intersects With	Incident Response Testing	IRO-06	Mechanisms exist to formally test incident response capabilities through realistic exercises to determine the operational effectiveness of those capabilities.	5	
101.635(c)(4)	N/A	Each exercise must test communication and notification procedures and elements of coordination, resource availability, and response.	Functional	Intersects With	Incident Response Testing	IRO-06	Mechanisms exist to formally test incident response capabilities through realistic exercises to determine the operational effectiveness of those capabilities.	5	
101.635(c)(5)	N/A	Exercises are a full test of the cybersecurity program and must include the substantial and active participation of the CySO(s).	Functional	Intersects With	Incident Response Testing	IRO-06	Mechanisms exist to formally test incident response capabilities through realistic exercises to determine the operational effectiveness of those capabilities.	5	
101.635(c)(6)	N/A	If any corrective action identified during an exercise is needed, it must be addressed and documented as soon as possible.	Functional	Subset Of	Root Cause Analysis (RCA) & Lessons Learned	IRO-13	Mechanisms exist to incorporate lessons learned from analyzing and resolving cybersecurity and data protection incidents to reduce the likelihood or impact of future incidents.	10	
101.640	Records and documentation	All records, reports, and other documents mentioned in this subpart must be created and maintained in accordance with 33 CFR 104.235 for U.S.-flagged vessels, 105.225 for facilities, and 106.230 for OCS facilities. At a minimum, the records must be created for the following activities: training, drills, exercises, cybersecurity threats, reportable cyber incidents, and audits of the Cybersecurity Plan.	Functional	Intersects With	Work Products	CPL-13	Mechanisms exist to produce work products (e.g., process artifacts) that demonstrate the ability to comply with applicable requirements.	8	
101.640	Records and documentation	All records, reports, and other documents mentioned in this subpart must be created and maintained in accordance with 33 CFR 104.235 for U.S.-flagged vessels, 105.225 for facilities, and 106.230 for OCS facilities. At a minimum, the records must be created for the following activities: training, drills, exercises, cybersecurity threats, reportable cyber incidents, and audits of the Cybersecurity Plan.	Functional	Intersects With	Media & Data Retention	DCH-18	Mechanisms exist to retain media and data in accordance with applicable statutory, regulatory and contractual obligations.	8	
101.645	Communications	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
101.645(a)	Communications	The CySO must have a means to effectively notify owners or operators and personnel of a U.S.-flagged vessel, facility, or OCS facility of changes in cybersecurity conditions at the U.S.-flagged vessel, facility, and OCS facility and document these means in Section 5 of the Cybersecurity Plan.	Functional	Subset Of	Status Reporting To Governing Body	GOV-01.2	Mechanisms exist to provide governance oversight reporting and recommendations to those entrusted to make executive decisions about matters considered material to the organization's Security, Compliance & Resilience Program (SCRPP).	10	
101.645(b)	Communications	Communication systems and procedures must allow effective and continuous communications between U.S.-flagged vessel, facility, and OCS facility security personnel, vessels interfacing with a facility or an OCS facility, the cognizant COTP, and national and local authorities with security responsibilities.	Functional	No Relationship	N/A	N/A	N/A	0	
101.650	Cybersecurity measures	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
101.650(a)	Account security measures	Each owner or operator of a U.S.-flagged vessel, facility, or OCS facility must ensure, at a minimum, the following account security measures are in place and documented in Section 7 of the Cybersecurity Plan: Automatic account lockout after repeated failed login attempts must be enabled on all password-protected IT systems;	Functional	Subset Of	Identity & Access Management (IAM)	IAC-01	Mechanisms exist to facilitate the implementation of identification and access management controls.	10	
101.650(a)(1)	N/A		Functional	Subset Of	Account Lockout	IAC-22	Mechanisms exist to enforce a limit for consecutive invalid login attempts by a user during an organization-defined time period and automatically locks the account when the maximum number of unsuccessful attempts is exceeded.	10	
101.650(a)(2)	N/A	Default passwords must be changed before using any IT or OT systems. When changing default passwords is not feasible, appropriate compensating security controls must be implemented and documented;	Functional	Equal	Default Authenticators	IAC-10.8	Mechanisms exist to ensure default authenticators are changed as part of account creation or system installation.	10	
101.650(a)(3)	N/A	A minimum password strength must be maintained on all IT and OT systems that are technically capable of password protection;	Functional	Subset Of	Password-Based Authentication	IAC-10.1	Mechanisms exist to enforce complexity, length and lifespan considerations to ensure strong criteria for password-based authentication.	10	
101.650(a)(4)	N/A	Multifactor authentication must be implemented on password-protected IT and remotely accessible OT systems. When multifactor authentication is not feasible, appropriate compensating security controls must be implemented and documented;	Functional	Subset Of	Multi-Factor Authentication (MFA)	IAC-06	Automated mechanisms exist to enforce Multi-Factor Authentication (MFA) for: (1) Remote network access; (2) Third-party Technology Assets, Applications and/or Services (TAAS); and/or (3) Non-console access to critical TAAS that store, transmit and/or process sensitive and/or regulated data.	10	
101.650(a)(5)	N/A	The principle of least privilege must be applied to administrator or otherwise privileged accounts on both IT and OT systems;	Functional	Equal	Least Privilege	IAC-21	Mechanisms exist to utilize the concept of least privilege, allowing only authorized access to processes necessary to accomplish assigned tasks in accordance with organizational business functions.	10	
101.650(a)(6)	N/A	The owner or operator must ensure that users maintain separate credentials on critical IT and OT systems; and	Functional	Intersects With	Separation of Duties (SoD)	HRS-11	Mechanisms exist to implement and maintain Separation of Duties (SoD) to prevent potential inappropriate activity without collusion.	5	
101.650(a)(6)	N/A	The owner or operator must ensure that users maintain separate credentials on critical IT and OT systems; and	Functional	Intersects With	Account Separation Between Infrastructure Environments	IAC-15.10	Mechanisms exist to separate non-privileged accounts between infrastructure environments to reduce the risk that a compromise in one infrastructure environment laterally affects another infrastructure environment.	8	
101.650(a)(6)	N/A	The owner or operator must ensure that users maintain separate credentials on critical IT and OT systems; and	Functional	Intersects With	Privileged Account Separation	IAC-16.2	Mechanisms exist to separate privileged accounts between infrastructure environments to reduce the risk of a compromise in one infrastructure environment from laterally affecting other infrastructure environments.	8	
101.650(a)(7)	N/A	The owner or operator must ensure that user credentials are removed or revoked when a user leaves the organization.	Functional	Intersects With	Onboarding, Transferring & Offboarding Personnel	HRS-01.1	Mechanisms exist to proactively govern the following personnel management actions: (1) Onboarding new personnel (e.g., new hires); (2) Transferring personnel into new roles within the organization; and (3) Offboarding personnel (e.g., termination of employment).	8	
101.650(a)(7)	N/A	The owner or operator must ensure that user credentials are removed or revoked when a user leaves the organization.	Functional	Intersects With	User Provisioning & De-Provisioning	IAC-07	Mechanisms exist to utilize a formal user registration and de-registration process that governs the assignment of access rights.	8	
101.650(b)	Device security measures	Device security measures. Each owner or operator or designated CySO of a U.S.-flagged vessel, facility, or OCS facility must ensure the following device security measures are in place, addressed in Section 6 of the Cybersecurity Plan, and made available to the Coast Guard upon request:	Functional	Subset Of	Statutory, Regulatory & Contractual Compliance	CPL-01	Mechanisms exist to facilitate the identification and implementation of relevant statutory, regulatory and contractual controls.	10	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
101.650(b)(1)	N/A	Develop and maintain a list of approved hardware, firmware, and software that may be installed on IT or OT systems. Any hardware, firmware, and software installed on IT and OT systems must be on the owner- or operator-approved list;	Functional	Equal	Approved Technologies	AST-01.4	Mechanisms exist to maintain a current list of approved technologies (hardware and software).	10	
101.650(b)(2)	N/A	Ensure applications running executable code are disabled by default on critical IT and OT systems;	Functional	Subset Of	Secure Baseline Configurations	CFG-02	Mechanisms exist to develop, document and maintain secure baseline configurations for Technology Assets, Applications and/or Services (TAAS) that are consistent with industry-accepted system hardening standards.	10	
101.650(b)(2)	N/A	Ensure applications running executable code are disabled by default on critical IT and OT systems;	Functional	Intersects With	Configure Technology Assets, Applications and/or Services (TAAS) for High-Risk Areas	CFG-02.5	Mechanisms exist to configure Technology Assets, Applications and/or Services (TAAS) utilized in high-risk areas with more restrictive baseline configurations.	8	
101.650(b)(3)	N/A	Maintain an accurate inventory of network-connected systems, including designation of critical IT and OT systems; and	Functional	Subset Of	Asset Inventories	AST-02	Mechanisms exist to perform inventories of Technology Assets, Applications, Services and/or Data (TAASD) that: (1) Accurately reflects the current TAASD in use; (2) Identifies authorized software products, including business justification details; (3) Is at the level of granularity deemed necessary for tracking and reporting; (4) Includes organization-defined information deemed necessary to achieve effective property accountability; and (5) Is available for review and audit by designated organizational personnel.	10	
101.650(b)(4)	N/A	Develop and maintain accurate documentation identifying the network map and OT device configuration information.	Functional	Subset Of	Network Diagrams & Data Flow Diagrams (DFDs)	AST-04	Mechanisms exist to maintain network architecture diagrams that: (1) Contain sufficient detail to assess the security of the network's architecture; (2) Reflect the current architecture of the network environment; and (3) Document all sensitive and/or regulated data flows.	10	
101.650(c)	Data security measures	Each owner or operator or designated CySO of a U.S.-flagged vessel, facility, or OCS facility must ensure the following data security measures are in place and documented in Section 4 of the Cybersecurity Plan:	Functional	Subset Of	Operationalizing Security, Compliance & Resilience Capabilities	GOV-15	Mechanisms exist to compel data and/or process owners to operationalize security, compliance and resilience practices for Technology Assets, Applications, Services and/or Data (TAASD) under their control.	10	
101.650(c)	Data security measures	Each owner or operator or designated CySO of a U.S.-flagged vessel, facility, or OCS facility must ensure the following data security measures are in place and documented in Section 4 of the Cybersecurity Plan:	Functional	Intersects With	Applied Security, Compliance and Resilience Controls Documentation	IAO-03	Mechanisms exist to generate authoritative documentation (e.g., System Security Plan (SSP)) that: (1) Identifies key architectural and implementation information on in-scope Technology Assets, Applications and/or Services (TAAS); (2) Reflects the current state of applied security, compliance and resilience controls on applicable People, Processes, Technologies, Data and/or Facilities (PPITDF) that are contained within the system boundary; and (3) Provides a historical record of applied security controls, including changes.	8	
101.650(c)(1)	N/A	Logs must be securely captured, stored, and protected so that they are accessible only by privileged users; and	Functional	Subset Of	Continuous Monitoring	MON-01	Mechanisms exist to facilitate the implementation of enterprise-wide monitoring controls.	10	
101.650(c)(1)	N/A	Logs must be securely captured, stored, and protected so that they are accessible only by privileged users; and	Functional	Intersects With	System Generated Alerts	MON-01.4	Mechanisms exist to generate, monitor, correlate and respond to alerts from physical, cybersecurity, data protection and supply chain activities to achieve integrated situational awareness.	5	
101.650(c)(1)	N/A	Logs must be securely captured, stored, and protected so that they are accessible only by privileged users; and	Functional	Intersects With	Security Event Monitoring	MON-01.8	Mechanisms exist to review event logs on an ongoing basis and escalate incidents in accordance with established timelines and procedures.	5	
101.650(c)(1)	N/A	Logs must be securely captured, stored, and protected so that they are accessible only by privileged users; and	Functional	Intersects With	Protection of Event Logs	MON-08	Mechanisms exist to protect event logs and audit tools from unauthorized access, modification and deletion.	5	
101.650(c)(1)	N/A	Logs must be securely captured, stored, and protected so that they are accessible only by privileged users; and	Functional	Intersects With	Access by Subset of Privileged Users	MON-08.2	Mechanisms exist to restrict access to the management of event logs to privileged users with a specific business need.	5	
101.650(c)(1)	N/A	Logs must be securely captured, stored, and protected so that they are accessible only by privileged users; and	Functional	Intersects With	Event Log Retention	MON-10	Mechanisms exist to retain event logs for a time period consistent with records retention requirements to provide support for after-the-fact investigations of security incidents and to meet statutory, regulatory and contractual retention requirements.	5	
101.650(c)(2)	N/A	Effective encryption must be deployed to maintain confidentiality of sensitive data and integrity of IT and OT traffic, when technically feasible.	Functional	Subset Of	Secure Baseline Configurations	CFG-02	Mechanisms exist to develop, document and maintain secure baseline configurations for Technology Assets, Applications and/or Services (TAAS) that are consistent with industry-accepted system hardening standards.	10	
101.650(c)(2)	N/A	Effective encryption must be deployed to maintain confidentiality of sensitive data and integrity of IT and OT traffic, when technically feasible.	Functional	Intersects With	Use of Cryptographic Controls	CRY-01	Mechanisms exist to facilitate the implementation of cryptographic protections controls using known public standards and trusted cryptographic technologies.	8	
101.650(c)(2)	N/A	Effective encryption must be deployed to maintain confidentiality of sensitive data and integrity of IT and OT traffic, when technically feasible.	Functional	Intersects With	Transmission Confidentiality	CRY-03	Cryptographic mechanisms exist to protect the confidentiality of data being transmitted.	5	
101.650(c)(2)	N/A	Effective encryption must be deployed to maintain confidentiality of sensitive data and integrity of IT and OT traffic, when technically feasible.	Functional	Intersects With	Encrypting Data At Rest	CRY-05	Cryptographic mechanisms exist to prevent unauthorized disclosure of data at rest.	5	
101.650(d)	Cybersecurity training for personnel	The training program to address requirements under this paragraph must be documented in Sections 2 and 4 of the Cybersecurity Plan.	Functional	Subset Of	Security, Compliance & Resilience-Minded Workforce	SAT-01	Mechanisms exist to facilitate the implementation of security workforce development and awareness controls.	10	
101.650(d)(1)	N/A	All personnel with access to the IT or OT systems, including contractors, whether part-time, full-time, temporary, or permanent, must have cybersecurity training in the following topics: Relevant provisions of the Cybersecurity Plan;	Functional	Subset Of	Security, Compliance & Resilience Awareness Training	SAT-02	Mechanisms exist to provide all employees and contractors appropriate security, compliance and resilience awareness education and training that is relevant for their job function.	10	
101.650(d)(1)(i)	N/A	Recognition and detection of cybersecurity threats and all types of cyber incidents;	Functional	Subset Of	Security, Compliance & Resilience Awareness Training	SAT-02	Mechanisms exist to provide all employees and contractors appropriate security, compliance and resilience awareness education and training that is relevant for their job function.	10	
101.650(d)(1)(ii)	N/A	Techniques used to circumvent cybersecurity measures;	Functional	Subset Of	Security, Compliance & Resilience Awareness Training	SAT-02	Mechanisms exist to provide all employees and contractors appropriate security, compliance and resilience awareness education and training that is relevant for their job function.	10	
101.650(d)(1)(iv)	N/A	Procedures for reporting a cyber incident to the CySO; and	Functional	Subset Of	Security, Compliance & Resilience Awareness Training	SAT-02	Mechanisms exist to provide all employees and contractors appropriate security, compliance and resilience awareness education and training that is relevant for their job function.	10	
101.650(d)(1)(v)	N/A	OT-specific cybersecurity training for all personnel whose duties include using OT.	Functional	Intersects With	Role-Based Security, Compliance & Resilience Training	SAT-03	Mechanisms exist to provide role-based security, compliance and resilience-related training: (1) Before authorizing access to the system or performing assigned duties; (2) When required by system changes; and (3) Annually thereafter.	8	
101.650(d)(2)	N/A	Key personnel with access to the IT or remotely accessible OT systems, including contractors, whether part-time, full-time, temporary, or permanent, must also have cybersecurity training in the following additional topics:	Functional	Intersects With	Role-Based Security, Compliance & Resilience Training	SAT-03	Mechanisms exist to provide role-based security, compliance and resilience-related training: (1) Before authorizing access to the system or performing assigned duties; (2) When required by system changes; and (3) Annually thereafter.	8	
101.650(d)(2)(i)	N/A	Understanding their roles and responsibilities during a cyber incident and response procedure; and	Functional	Intersects With	Role-Based Security, Compliance & Resilience Training	SAT-03	Mechanisms exist to provide role-based security, compliance and resilience-related training: (1) Before authorizing access to the system or performing assigned duties; (2) When required by system changes; and (3) Annually thereafter.	8	
101.650(d)(2)(ii)	N/A	Maintaining current knowledge of changing cybersecurity threats and countermeasures.	Functional	Intersects With	Role-Based Security, Compliance & Resilience Training	SAT-03	Mechanisms exist to provide role-based security, compliance and resilience-related training: (1) Before authorizing access to the system or performing assigned duties; (2) When required by system changes; and (3) Annually thereafter.	8	
101.650(d)(3)	N/A	When personnel must access IT or OT systems but are unable to receive cybersecurity training as specified in paragraphs (d)(1) and (2) of this section, they must be accompanied or monitored by a person who has completed the training specified in paragraphs (d)(1) and (2) of this section.	Functional	Intersects With	Maintenance Personnel Without Appropriate Access	MNT-06.1	Mechanisms exist to ensure the risks associated with maintenance personnel who do not have appropriate access authorizations, clearances or formal access approvals are appropriately mitigated.	5	

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **US - 33 CFR Part 101 Subpart F (up to date as of 4 - 17 - 2026)**

Focal Document URL: <https://www.ecfr.gov/current/title-33/chapter-I/subchapter-H/part-101/subpart-F>

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-usa-federal-law-33-cfr-part-101-subpart-f.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
101.650(d)(3)	N/A	When personnel must access IT or OT systems but are unable to receive cybersecurity training as specified in paragraphs (d)(1) and (2) of this section, they must be accompanied or monitored by a person who has completed the training specified in paragraphs (d)(1) and (2) of this section.	Functional	Intersects With	Non-System Related Maintenance	MNT-06.2	Mechanisms exist to ensure that non-escorted personnel performing non-IT maintenance activities in the physical proximity of systems have required access authorizations.	5	
101.650(d)(3)	N/A	When personnel must access IT or OT systems but are unable to receive cybersecurity training as specified in paragraphs (d)(1) and (2) of this section, they must be accompanied or monitored by a person who has completed the training specified in paragraphs (d)(1) and (2) of this section.	Functional	Intersects With	Restrict Unescorted Access	PES-06.3	Physical access control mechanisms exist to restrict unescorted access to facilities to personnel with required security clearances, formal access authorizations and validate the need for access.	5	
101.650(d)(4)	N/A	All personnel must complete the training specified in paragraphs (d)(1)(i) through (v) of this section by January 12, 2026, and annually thereafter. Key personnel must complete the training specified in paragraph (d)(2) of this section by January 12, 2026, and annually thereafter, or more frequently as needed. Training for new personnel not in place at the time of the effective date of this rule must be completed within 5 days of gaining system access, but no later than within 30 days of hiring, and annually thereafter. Training for personnel on new IT or OT systems not in place at the time of the effective date of this rule must be completed within 5 days of system access, and annually thereafter. All personnel must complete the training specified in paragraph (d)(1)(i) within 60 days of receiving approval of the Cybersecurity Plan. The training must be documented and maintained in the owner's or operator's records in accordance with 33 CFR 104.235 for U.S.-flagged vessels, 105.225 for facilities, and 106.230 for OCS facilities.	Functional	Intersects With	Role-Based Security, Compliance & Resilience Training	SAT-03	Mechanisms exist to provide role-based security, compliance and resilience-related training: (1) Before authorizing access to the system or performing assigned duties; (2) When required by system changes; and (3) Annually thereafter.	8	
101.650(d)(4)	N/A	All personnel must complete the training specified in paragraphs (d)(1)(i) through (v) of this section by January 12, 2026, and annually thereafter. Key personnel must complete the training specified in paragraph (d)(2) of this section by January 12, 2026, and annually thereafter, or more frequently as needed. Training for new personnel not in place at the time of the effective date of this rule must be completed within 5 days of gaining system access, but no later than within 30 days of hiring, and annually thereafter. Training for personnel on new IT or OT systems not in place at the time of the effective date of this rule must be completed within 5 days of system access, and annually thereafter. All personnel must complete the training specified in paragraph (d)(1)(i) within 60 days of receiving approval of the Cybersecurity Plan. The training must be documented and maintained in the owner's or operator's records in accordance with 33 CFR 104.235 for U.S.-flagged vessels, 105.225 for facilities, and 106.230 for OCS facilities.	Functional	Intersects With	Security, Compliance & Resilience Training Records	SAT-04	Mechanisms exist to document, retain and monitor individual training activities, including: (1) Initial security, compliance and resilience awareness training; (2) Recurring awareness training; and (3) Technology Assets, Applications and/or Services (TAAS)-specific training.	5	
101.650(e)	Risk management	Each owner or operator or designated CySO of a U.S.-flagged vessel, facility, or OCS facility must ensure the following measures for risk management are in place and documented in Sections 11 and 12 of the Cybersecurity Plan.	Functional	Subset Of	Statutory, Regulatory & Contractual Compliance	CPL-01	Mechanisms exist to facilitate the identification and implementation of relevant statutory, regulatory and contractual controls.	10	
101.650(e)(1)	Cybersecurity Assessment	Each owner or operator or designated CySO of a U.S.-flagged vessel, facility, or OCS facility must ensure completion of a Cybersecurity Assessment that addresses each covered U.S.-flagged vessel, facility, and OCS facility. A Cybersecurity Assessment must be conducted no later than July 16, 2027, and annually thereafter. However, the Cybersecurity Assessment must be conducted sooner than annually if there is a change in ownership of a U.S.-flagged vessel, facility, or OCS facility. In conducting the Cybersecurity Assessment, the owner or operator must—	Functional	Subset Of	Assessments	IAO-02	Mechanisms exist to formally assess the security, compliance and resilience controls in Technology Assets, Applications and/or Services (TAAS) through Information Assurance Program (IAP) activities to determine the extent to which the controls are implemented correctly, operating as intended and producing the desired outcome with respect to meeting expected requirements.	10	
101.650(e)(1)(i)	N/A	Analyze all networks to identify vulnerabilities to critical IT and OT systems and the risk posed by each digital asset;	Functional	Subset Of	Assessments	IAO-02	Mechanisms exist to formally assess the security, compliance and resilience controls in Technology Assets, Applications and/or Services (TAAS) through Information Assurance Program (IAP) activities to determine the extent to which the controls are implemented correctly, operating as intended and producing the desired outcome with respect to meeting expected requirements.	10	
101.650(e)(1)(ii)	N/A	Validate the Cybersecurity Plan;	Functional	Subset Of	Assessments	IAO-02	Mechanisms exist to formally assess the security, compliance and resilience controls in Technology Assets, Applications and/or Services (TAAS) through Information Assurance Program (IAP) activities to determine the extent to which the controls are implemented correctly, operating as intended and producing the desired outcome with respect to meeting expected requirements.	10	
101.650(e)(1)(iii)	N/A	Document recommendations and resolutions in the Vessel Security Assessment (VSA), Facility Security Assessment (FSA), or OCS FSA, in accordance with 33 CFR 104.305, 105.305, and 106.305;	Functional	Intersects With	Security Assessment Report (SAR)	IAO-02.4	Mechanisms exist to produce a Security Assessment Report (SAR) at the conclusion of a security assessment to certify the results of the assessment and assist with any remediation actions.	8	
101.650(e)(1)(iv)	N/A	Document and ensure patching or implementing of documented compensating controls for all KEVs in critical IT or OT systems, without delay; and	Functional	Subset Of	Capabilities Deficiency Tracking	IAO-05	Mechanisms exist to govern identified deficiencies (e.g., Plan of Action and Milestones (POA&M) or similar methodology) that formally documents, at a minimum: (1) Deficiency tracking number; (2) Applicable security, compliance and/or resilience control; (3) Description of the deficiency(ies); (4) Risk associated with the deficiency(ies); (5) Source deficiency identification/detection; (6) Temporary compensating controls, if applicable; (7) Point of Contact (POC) (e.g., asset/process owner); (8) Resources required to conduct remediation actions; (9) Planned remedial actions to the deficiency(ies); (10) Proposed remediation timeline; and (11) Disposition statement (e.g., closedout summary).	10	
101.650(e)(1)(v)	N/A	Incorporate recommendations and resolutions from paragraph (e)(1)(iii) of this section into the Cybersecurity Plan through an amendment, in accordance with § 101.630(e).	Functional	Subset Of	Applied Security, Compliance and Resilience Controls Documentation	IAO-03	Mechanisms exist to generate authoritative documentation (e.g., System Security Plan (SSP)) that: (1) Identifies key architectural and implementation information on in-scope Technology Assets, Applications and/or Services (TAAS); (2) Reflects the current state of applied security, compliance and resilience controls on applicable People, Processes, Technologies, Data and/or Facilities (PPTDF) that are contained within the system boundary; and (3) Provides a historical record of applied security controls, including changes.	10	
101.650(e)(2)	Penetration testing	In conjunction with Cybersecurity Plan renewal, the owner, operator, or designated CySO must ensure that a penetration test has been completed.	Functional	Intersects With	Penetration Testing	VPM-07	Mechanisms exist to conduct penetration testing on Technology Assets, Applications and/or Services (TAAS).	5	
101.650(e)(3)	Routine system maintenance	Each owner or operator or a designated CySO of a U.S.-flagged vessel, facility, or OCS facility must ensure the following measures for routine system maintenance are in place:	Functional	Subset Of	Statutory, Regulatory & Contractual Compliance	CPL-01	Mechanisms exist to facilitate the identification and implementation of relevant statutory, regulatory and contractual controls.	10	
101.650(e)(3)(i)	N/A	Ensure patching or implementation of documented compensating controls for all KEVs in critical IT or OT systems, without delay;	Functional	Intersects With	Software & Firmware Patching	VPM-05	Mechanisms exist to conduct software patching for all deployed Technology Assets, Applications and/or Services (TAAS), including firmware.	5	
101.650(e)(3)(ii)	N/A	Maintain a method to receive and act on publicly submitted vulnerabilities;	Functional	Intersects With	Threat Intelligence Feeds	THR-03	Mechanisms exist to maintain situational awareness of vulnerabilities and evolving threats by leveraging the knowledge of attacker tactics, techniques and procedures to facilitate the implementation of preventative and compensating controls.	5	
101.650(e)(3)(iii)	N/A	Maintain a method to receive and act on publicly submitted vulnerabilities;	Functional	Intersects With	Automated Software & Firmware Updates	VPM-05.4	Automated mechanisms exist to install the latest stable versions of security-relevant software and firmware updates.	5	
101.650(e)(3)(iii)	N/A	Maintain a method to share threat and vulnerability information with external stakeholders;	Functional	Intersects With	Threat Intelligence Reporting	THR-03.1	Mechanisms exist to utilize external threat intelligence feeds to generate and disseminate organization-specific security alerts, advisories and/or directives.	5	
101.650(e)(3)(iv)	N/A	Ensure there are no exploitable channels directly exposed to internet-accessible systems;	Functional	Intersects With	Defense-In-Depth (DiD) Architecture	SEA-03	Mechanisms exist to implement security functions as a layered structure minimizing interactions between layers of the design and avoiding any dependence by lower layers on the functionality or correctness of higher layers.	5	
101.650(e)(3)(iv)	N/A	Ensure there are no exploitable channels directly exposed to internet-accessible systems.	Functional	Intersects With	Direct Internet Access Restrictions	NET-06.5	Mechanisms exist to prohibit, or strictly-control, Internet access from sensitive and/or regulated data enclaves (secure zones).	5	
101.650(e)(3)(v)	N/A	Ensure no OT is connected to the publicly accessible internet unless explicitly required for operation; and	Functional	Subset Of	Operational Technology (OT)	EMB-03	Mechanisms exist to proactively manage the security, compliance and resilience risks associated with Operational Technology (OT).	10	

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **US - 33 CFR Part 101 Subpart F (up to date as of 4 - 17 - 2026)**

Focal Document URL: <https://www.ecfr.gov/current/title-33/chapter-I/subchapter-H/part-101/subpart-F>

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-usa-federal-law-33-cfr-part-101-subpart-f.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
101.650(e)(3)(v)	N/A	Ensure no OT is connected to the publicly accessible internet unless explicitly required for operation; and	Functional	Intersects With	Direct Internet Access Restrictions	NET-06.5	Mechanisms exist to prohibit, or strictly-control, internet access from sensitive and/or regulated data enclaves (secure zones).	5	
101.650(e)(3)(vi)	N/A	Conduct vulnerability scans as specified in the Cybersecurity Plan.	Functional	Intersects With	Vulnerability Scanning	VPM-06	Mechanisms exist to detect vulnerabilities and configuration errors by routine vulnerability scanning of systems and applications.	5	
101.650(f)	Supply chain	Each owner or operator or designated CySO must ensure:	Functional	Subset Of	Statutory, Regulatory & Contractual Compliance	CPL-01	Mechanisms exist to facilitate the identification and implementation of relevant statutory, regulatory and contractual controls.	10	
101.650(f)(1)	N/A	Consider cybersecurity capability as criteria for evaluation to procure IT and OT systems or services;	Functional	Subset Of	Capacity & Performance Management	CAP-01	Mechanisms exist to facilitate the implementation of capacity management controls to ensure optimal system performance to meet expected and anticipated future capacity requirements.	10	
101.650(f)(2)	N/A	Establish a process through which all IT and OT vendors notify of vulnerabilities or reportable cyber incidents without delay; and	Functional	Subset Of	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets, Applications, Services and/or Data (TAASD).	10	
101.650(f)(3)	N/A	Monitor and document all third-party remote connections to detect cyber incidents.	Functional	Subset Of	Continuous Monitoring	MON-01	Mechanisms exist to facilitate the implementation of enterprise-wide monitoring controls.	10	
101.650(f)(3)	N/A	Monitor and document all third-party remote connections to detect cyber incidents.	Functional	Intersects With	Inbound & Outbound Communications Traffic	MON-01.3	Mechanisms exist to continuously monitor inbound and outbound communications traffic for unusual or unauthorized activities or conditions.	5	
101.650(g)	Resilience	Each owner or operator or designated CySO must ensure:	Functional	Subset Of	Statutory, Regulatory & Contractual Compliance	CPL-01	Mechanisms exist to facilitate the identification and implementation of relevant statutory, regulatory and contractual controls.	10	
101.650(g)(1)	N/A	Report reportable cyber incidents to the NRC without delay;	Functional	Intersects With	Cyber Incident Reporting for Sensitive / Regulated Data	IRO-10.2	Mechanisms exist to report sensitive and/or regulated data incidents in a timely manner.	5	
101.650(g)(2)	N/A	Develop, implement, maintain, and exercise the Cyber Incident Response Plan;	Functional	Intersects With	Incident Response Plan (IRP)	IRO-04	Mechanisms exist to maintain and make available a current and viable Incident Response Plan (IRP) to all stakeholders.	5	
101.650(g)(3)	N/A	Periodically validate the effectiveness of the Cybersecurity Plan; and	Functional	Intersects With	Conformity Assessment	CPL-01.4	Mechanisms exist to conduct assessments to demonstrate security, compliance and/or resilience capability conformity with applicable cybersecurity and data protection laws, regulations and/or contractual obligations.	5	
101.650(g)(4)	N/A	Perform backup of critical IT and OT systems.	Functional	Subset Of	Data Backups	BCD-11	Mechanisms exist to create recurring backups of data, software and/or system images, as well as verify the integrity of these backups, to ensure the availability of the data to satisfy Recovery Time Objectives (RTOs) and Recovery Point Objectives (RPOs).	10	
101.650(h)	Network segmentation	Each owner or operator must ensure:	Functional	Subset Of	Statutory, Regulatory & Contractual Compliance	CPL-01	Mechanisms exist to facilitate the identification and implementation of relevant statutory, regulatory and contractual controls.	10	
101.650(h)(1)	N/A	Implement segmentation between IT and OT networks; and	Functional	Subset Of	Network Segmentation (macrosegmentation)	NET-06	Mechanisms exist to implement network segmentation within network architectures to isolate Technology Assets, Applications and/or Services (TAAS) from other network resources.	10	
101.650(h)(2)	N/A	Verify that all connections between IT and OT systems are logged and monitored.	Functional	Intersects With	Inbound & Outbound Communications Traffic	MON-01.3	Mechanisms exist to continuously monitor inbound and outbound communications traffic for unusual or unauthorized activities or conditions.	5	
101.650(h)(2)	N/A	Verify that all connections between IT and OT systems are logged and monitored.	Functional	Intersects With	System Generated Alerts	MON-01.4	Mechanisms exist to generate, monitor, correlate and respond to alerts from physical, cybersecurity, data protection and supply chain activities to achieve integrated situational awareness.	5	
101.650(i)	Physical security	Each owner or operator must ensure:	Functional	Subset Of	Statutory, Regulatory & Contractual Compliance	CPL-01	Mechanisms exist to facilitate the identification and implementation of relevant statutory, regulatory and contractual controls.	10	
101.650(i)(1)	N/A	Limit physical access to OT and related IT equipment to authorized personnel; and	Functional	Intersects With	Physical Access Authorizations	PES-02	Physical access control mechanisms exist to maintain a current list of personnel with authorized access to organizational facilities (except for those areas within the facility officially designated as publicly accessible).	5	
101.650(i)(1)	N/A	Limit physical access to OT and related IT equipment to authorized personnel; and	Functional	Intersects With	Role-Based Physical Access	PES-02.1	Physical access control mechanisms exist to authorize physical access to facilities based on the position or role of the individual.	8	
101.650(i)(1)	N/A	Limit physical access to OT and related IT equipment to authorized personnel; and	Functional	Subset Of	Physical Access Control	PES-03	Physical access control mechanisms exist to enforce physical access authorizations for all physical access points (including designated entry/exit points) to facilities (excluding those areas within the facility officially designated as publicly accessible).	10	
101.650(i)(2)	N/A	Ensure unauthorized media and hardware are not connected to IT and OT infrastructure.	Functional	Subset Of	Asset Governance	AST-01	Mechanisms exist to facilitate an IT Asset Management (ITAM) program to implement and manage asset management controls.	10	
101.650(i)(2)	N/A	Ensure unauthorized media and hardware are not connected to IT and OT infrastructure.	Functional	Intersects With	Authorized To Connect	AST-01.5	Mechanisms exist to maintain a list of Technology Asset, Application and/or Service (TAAS) that are authorized to connect to organizational Technology Assets, Applications, Services and/or Data (TAASD).	8	
101.650(i)(2)	N/A	Ensure unauthorized media and hardware are not connected to IT and OT infrastructure.	Functional	Intersects With	Automated Unauthorized Component Detection	AST-02.2	Automated mechanisms exist to detect and alert upon the detection of unauthorized hardware, software and firmware components.	5	
101.655	Cybersecurity compliance dates	All Cybersecurity Plans mentioned in this subpart must be submitted to the Coast Guard for review and approval no later than July 16, 2027, according to 33 CFR 104.410 for U.S.-flagged vessels, 33 CFR 105.410 for facilities, or 33 CFR 106.410 for OCS facilities.	Functional	No Relationship	N/A	N/A	N/A	0	
101.660	Cybersecurity compliance documentation	Each owner or operator must ensure that the cybersecurity portion of their Plan and penetration test results are available to the Coast Guard upon request. The Alternative Security Program provisions apply to cybersecurity compliance documentation and are addressed in 33 CFR 104.140 for vessels, 33 CFR 105.140 for facilities, and 33 CFR 106.135 for OCS facilities.	Functional	Subset Of	Ability To Demonstrate Conformity	CPL-01.3	Mechanisms exist to ensure the organization is able to demonstrate security, compliance and/or resilience capability conformity with applicable cybersecurity and data protection laws, regulations and/or contractual obligations.	10	
101.665	Noncompliance waivers and equivalents	An owner or operator, after completion of the required Cybersecurity Assessment, may seek a waiver or an equivalence determination for the requirements in subpart F using the standards and submission procedures applicable to a U.S.-flagged vessel, facility, or OCS facility as outlined in 33 CFR 101.130, 104.130, 104.135, 105.130, 105.135, 106.125, or 106.130. If an owner or operator must temporarily deviate from the requirements in this part, they must notify the cognizant COTP for facilities or OCS facilities, or the MSC for U.S.-flagged vessels, and may request temporary permission to continue to operate under the provisions as outlined in 33 CFR 104.125, 105.125, or 106.120.	Functional	No Relationship	N/A	N/A	N/A	0	
101.670	Severability	Any provision of this subpart held to be invalid or unenforceable as applied to any person or circumstance shall be construed so as to continue to give the maximum effect to the provision permitted by law, including as applied to persons not similarly situated or to dissimilar circumstances, unless such holding is that the provision of this subpart is invalid and unenforceable in all circumstances, in which event the provision shall be severable from the remainder of this subpart and shall not affect the remainder thereof.	Functional	No Relationship	N/A	N/A	N/A	0	